

CORPORATE ACCESS CONTROL AND PASSWORD SECURITY POLICY

POL-SEC-2026-004 | Version 1.0 | Internal Use Only

Aligned to ISO/IEC 27001:2022 Annex A Access & Identity Controls and the Nigeria Data Protection Act (NDPA) 2023

1. Document Control

1.1 Document Information

Document Title	Corporate Access Control and Password Security Policy
Document ID	POL-SEC-2026-004
Version	1.0
Classification	Internal Use Only
Effective Date	August 26, 2026
Review Cycle	Annual

1.2 Document History

Version	Date	Author	Description of Change
1.0	August 26, 2026	Tosin Tuwase, Compliance Analyst (Practice)	Initial drafting and alignment with ISO 27001 controls.

1.3 Document Approvals

Name / Role	Department	Signature / Status	Date
Chief Information Security Officer	Information Security	Pending Review	[Date]
Director of IT Operations	Infrastructure	Pending Review	[Date]

Honesty note: This is a practice policy document, authored as part of a self-directed GRC portfolio built on the author's final-year Computer Science degree project (an Applicant Assistant Chatbot System). Named roles, departments, and approval signatures are illustrative and do not represent a real organization or a live enterprise deployment.

2. Purpose

The purpose of this policy is to establish a comprehensive framework for securing corporate information assets by defining strict standards for user identification, authentication, and access control management. Unregulated or weak authentication mechanisms expose the organization to significant operational, financial, and regulatory risks, including data breaches, unauthorized system modification, and credential stuffing attacks.

This policy ensures the confidentiality, integrity, and availability of corporate data by aligning access management practices with global information security standards: specifically ISO/IEC 27001:2022 Annex A controls A.5.15 (Access control), A.5.16 (Identity management), A.5.17 (Authentication information), A.8.2 (Privileged access rights), A.8.3 (Information access restriction), and A.8.5 (Secure authentication), which collectively correspond to the Access Control domain (Control A.9) under the earlier ISO/IEC 27001:2013 structure, and local statutory requirements under the Nigeria Data Protection Act (NDPA) 2023.

3. Scope

This policy applies universally to all information systems, networks, applications, and computing devices owned, leased, or operated by the organization.

3.1 Personnel Scope

The mandates of this document apply to all individuals granted access to corporate assets, including:

- Full-time and part-time employees.
- Contract workers, third-party vendors, and consultants.

- Interns, trainees, and temporary staff.

3.2 System Scope

This policy encompasses all technical environments, including but not limited to:

- On-premise infrastructure and local area networks (LAN).
- Cloud environments (SaaS, PaaS, IaaS) containing corporate or client data.
- Internal database management systems (e.g., PostgreSQL production layers).
- Public-facing application backends and administrative consoles.

4. Policy Statements

4.1 Identification and Authorization Principles

- **Least Privilege:** Access rights must be granted based strictly on the "need-to-know" principle. Users shall only be provisioned with the minimum privileges required to perform their specific job functions.
- **Separation of Duties:** To prevent fraudulent activities and unauthorized system manipulation, critical administrative duties (such as system deployment and system auditing) must be split between separate personnel. No single user shall possess end-to-end control over a critical financial or technical pipeline.
- **Unique Identification:** Every user must be assigned a unique, non-shareable identifier (User ID). The use of generic or shared accounts (e.g., admin, guest, developer) for standard business operations is strictly prohibited.

4.2 Password Complexity Standards

All system-generated and user-defined passwords must strictly adhere to the following technical constraints:

- **Minimum Length:** Passwords must be a minimum of fourteen (14) characters in length.
- **Character Variety:** Passwords must contain characters from at least three (3) of the following four groups: Uppercase letters (A–Z), Lowercase letters (a–z), Numerical digits (0–9), and Special characters (e.g., !, @, #, \$, %, ^, *).
- **Password History:** The system must maintain a history of the last twelve (12) passwords. Users are prohibited from reusing any password within this history.
- **Password Expiration:** Standard user passwords must be changed at least once every 365 days. Privileged and administrative accounts must rotate passwords every 90 days.
- **Prohibited Words:** Passwords must not contain dictionary words, usernames, common keyboard sequences (e.g., 123456, qwerty), or easily guessable corporate nomenclature.

4.3 Multi-Factor Authentication (MFA) Requirements

- **Mandatory Enforcement:** MFA must be enforced globally for all employees and external contractors.
- **Remote Access:** MFA is strictly mandatory for any remote access connection to the corporate network via VPN or Zero Trust Network Access (ZTNA) solutions.
- **Approved Authentication Factors:** Permissible secondary factors include hardware tokens, time-based one-time password (TOTP) applications (e.g., Google Authenticator, Microsoft Authenticator), or biometric verification. Authentication via SMS or voice call is deprecated and prohibited due to SIM-swapping vulnerabilities.

4.4 Account Lockout and Brute-Force Protection

- **Lockout Threshold:** Information systems must automatically lock a user account after five (5) consecutive failed authentication attempts within a fifteen (15) minute window.
- **Lockout Duration:** Locked accounts will remain disabled for a mandatory duration of thirty (30) minutes before auto-unlocking, or must require explicit verification and manual intervention by the IT Service Desk.

4.5 User Account Provisioning and De-provisioning Lifecycle

- **Request and Approval:** All new account creations or privilege escalation requests must be officially logged via the IT ticketing system and require formal, documented sign-off from the user's line manager and the system owner.
- **Quarterly Access Reviews:** System administrators must conduct a formal audit of user access rights every ninety (90) days to identify and revoke stale accounts, orphan accounts, or instances of privilege creep.
- **Immediate De-provisioning:** Upon the termination or resignation of an employee or contractor, HR must immediately notify the IT Security department. All logical and physical access privileges must be completely revoked or disabled within a maximum of two (2) hours from the official time of separation.

5. Enforcement and Penalties

Compliance with this policy is mandatory. The Information Security department shall continuously monitor corporate networks and directory services to ensure baseline compliance configurations are maintained.

5.1 Non-Compliance Handling

Any employee, contractor, or vendor found to have intentionally bypassed, modified, or violated the control mechanisms outlined in this document will be subject to immediate disciplinary investigation.

5.2 Penalties

Penalties for policy violations will be enforced objectively based on severity and intent. Sanctions may include:

- Mandatory security awareness retraining.
- Temporary suspension of corporate network privileges.
- Formal written warnings placed on the employee's permanent HR file.
- Termination of employment or contract.
- Civil or criminal legal action in accordance with local statutes governing corporate data breach negligence.